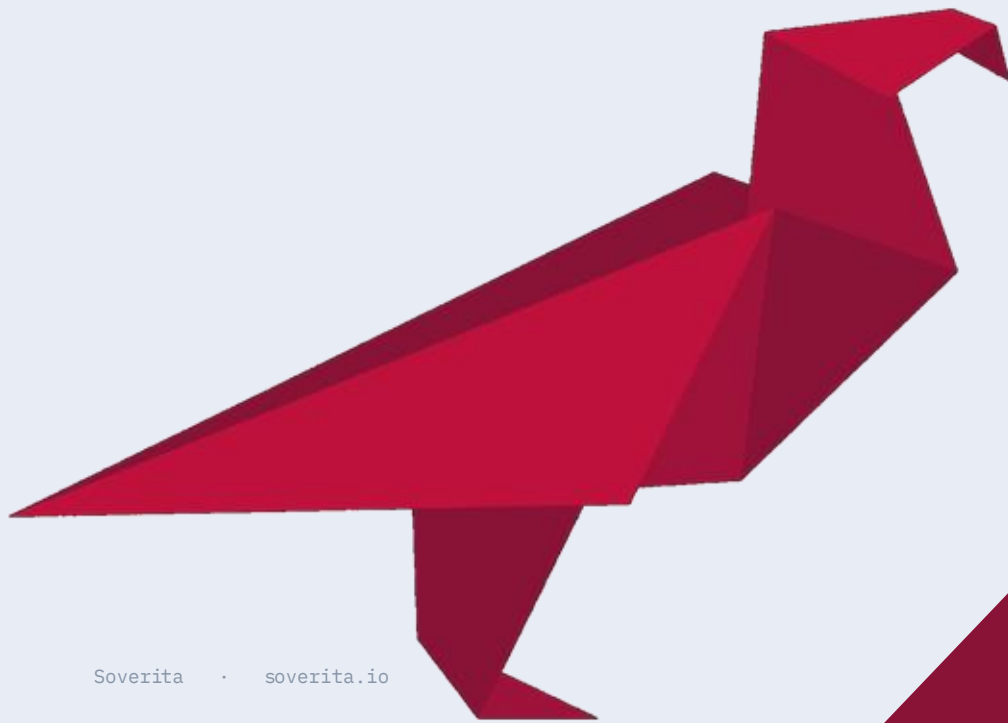




Tenant-Sec

*How to pick and choose your
secure and sovereign cloud*

About me

WHO I AM

Yavor Papazov, CISO @ Soverita
yavor@soverita.io

- 15 years in infosec, 20 in SW dev
- Lead Security Researcher @ ESI ☺
- Lead Cloud Security Researcher @ VMware SecureState
- Lead Product & PaaS Security Architect, GCC sovereign AI cloud
- Cybersecurity Advisor to the Minister of e-Governance

WHY TENANT-SEC

“I need a secure EU sovereign cloud”

We needed to have:

- **IAM with custom identity roles/policies**
- **IAM with resource-based policies**
- **Encryption with CMK for VMs**
- **Encryption with CMK for S3/object storage**

No provider docset let me compare those well

INTRO

An open framework for tenant-operable security.

THE FRAMEWORK

*Compare what a tenant can configure,
enforce, verify, and operate.*

Security capabilities, compared per cloud offering.

A decision aid, not a compliance opinion.

You will see the assessment system and its current failure modes.

TODAY

*EU cloud dilemma → methodology → AI assessment
pipeline → live inspection*

*“The goal is not to crown a
‘best cloud.’ It is to make
trade-offs inspectable.”*

“Compliant” is too low-resolution

A pass/fail answer does not say what a tenant can configure and enforce

What binary assurance says	What a tenant still needs to know
“Encryption is available”	Which services support my keys? Can I enforce it?
“Logging is supported”	Which control planes are covered? Can logs be locked?
“IAM exists”	Can policy override an accidental allow?
“Data stays in Europe”	Primary data only, or backups, metadata, and support paths too?

Binary checks hide:

Maturity tenant-built automation and managed policy look identical

Coverage one supported service can mask gaps across the catalogue

Uncertainty missing documentation is easily misreported as absence

Certifications still matter. They answer a different question.

Europe's cloud dilemma is not one-dimensional

Scale and sovereignty pull in different directions.

SOVEREIGNTY CAN MEAN

Jurisdiction	Operator access
Supply chain	Portability
Technology control	Resilience

DORA and the Data Act make third-party risk, exit, and portability operational concerns.

"Hosted in the EU" is relevant evidence. It is not a complete security or sovereignty conclusion.

EU Data Act explained, European Commission

70%

of Europe's cloud infrastructure market held by AWS, Microsoft, and Google in 2025

Synergy Research, 2025

15%

held collectively by European providers

Synergy Research, 2025

8

sovereignty objectives in EU procurement evaluation, not geography alone

EU Cloud Sovereignty Framework

Compare an offering, not a logo

Unit of assessment: provider + offering + region/partition + service + edition + date

Tenant controls

Result layer 1

L0–L3, MIX, or an explicit non-score state

Provider vignette

Result layer 2

Legal, operations, subcontracting, audit/exit, continuity

Certifications

Result layer 3

Typed qualifications with exact offering and service scope

OVHcloud

Public Cloud ≠ Bare Metal Pod

Hetzner

Cloud ≠ Dedicated/Robot

AWS

Commercial regions ≠ European
Sovereign Cloud

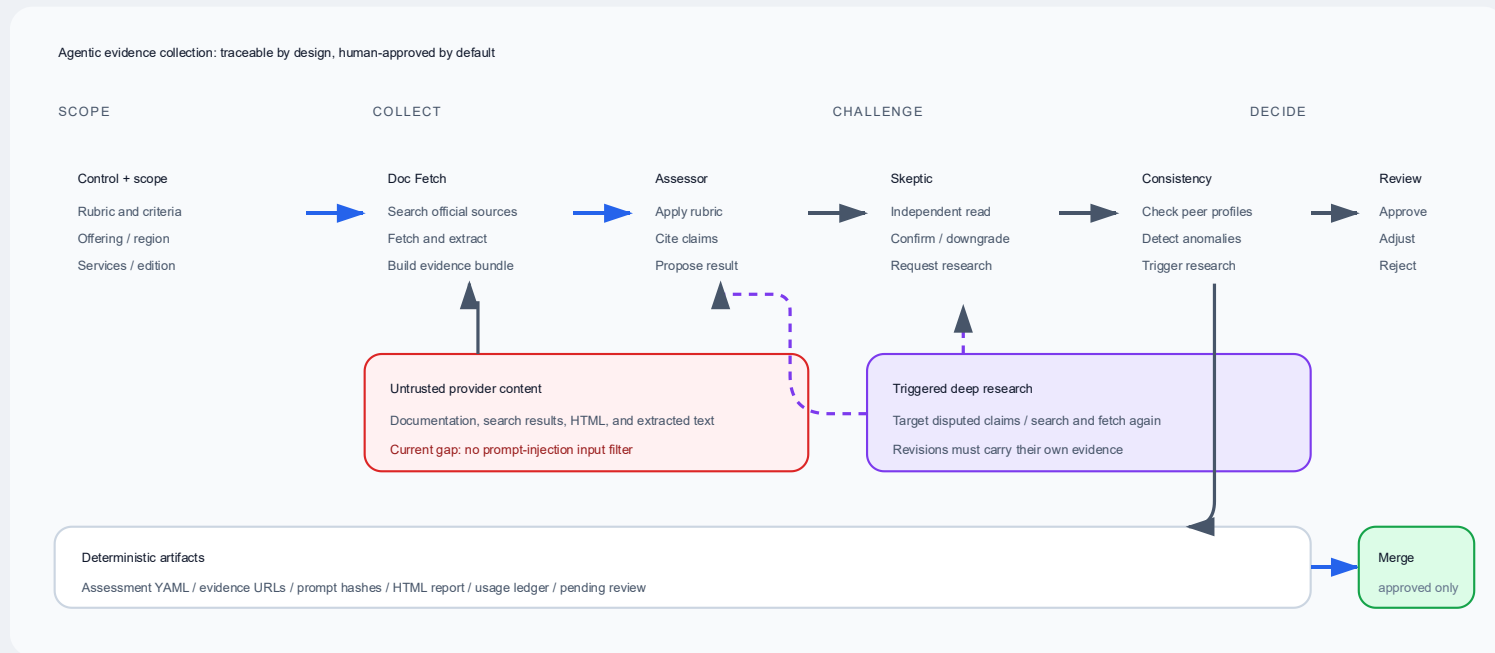
A company name is not a security boundary: offerings differ in operators, contracts, catalogues, regions, and qualifications.

Preserve uncertainty instead of manufacturing precision



L0	Impossible from tenant space	Requires affirmative evidence
L1	Tenant-built loop	Possible only with a tenant-built processing loop
L2	Managed, with limits	Managed capability, with meaningful limitations
L3	Managed and policy-driven	Managed, policy-driven, and customizable
MIX	Per-service variation	Honest per-service variation instead of an average
?	Non-scores stay visible	unknown · conflicting · not_assessed · not_applicable · out_of_scope
!	Two ranking rules	A failed search is unknown, never L0. Must-haves and required qualifications are eligibility gates, not footnotes under an average.

From documentation to a reviewable assessment



Open-source plan: publish the collection pipeline after security hardening. Today, fetched content is untrusted and has no prompt-injection input filter.

Release-candidate reality check

RC1 produced a complete matrix: 4 providers × 62 controls = 248 assessment artifacts

97.6%

Reached human review

242 OF 248 ARTIFACTS

6 ended in an explicit pipeline error.

236

Scored recommendations

12 UNKNOWN OR UNSCORED

L0 9 · L1 27 · L2 87 · L3 70 · MIX 43

2,911

Model calls

657 SEARCHES · 681 FETCHES

23.1M input and 5.5M output tokens.

\$0.56

Per assessment

\$139.72 CURRENT ARTIFACTS

Model cost attached to the 248 current per-control ledgers.

\$196.97

Batch ledger charged

INCL. FAILED AND RETRIED

Search-provider cost is tracked separately.

248

Reviews still pending

THE BOUNDARY

Agent recommendations, not publication-ready provider scores.

Live demo I: inspect before ranking

Demo message: a score is the end of a trace, not the start of an argument.

Controls Explorer

STEPS 1-4

1. Focus one provider and show the L0/L1/L2/L3/MIX distribution
2. Filter to a decisive control: `log.control-plane-audit`
3. Open the detail panel: criteria → service breakdown → evidence → mappings
4. Show how **MIX** prevents one supported service from hiding another gap

Evaluator

STEPS 5-7

5. Load the EU regulated fintech profile
6. Change a must-have or aggregation rule
7. Compare the summary with the raw control matrix

Live demo II: make the decision reproducible

Ask the audience: would changing the workload profile change the preferred trade-off?

RUN IN THE TERMINAL

```
tenant-sec validate providers/scaleway.yaml

tenant-sec detail --provider scaleway \
  --domain logging -v

tenant-sec compare --providers aws,gcp,scaleway \
  --domain encryption

tenant-sec score \
  --profile profiles/eu-regulated-fintech.yaml
```

THE PYTHON ENGINE ADDS

Catalogue completeness and service coverage

Must-have and certification eligibility gates

Staleness and publication reasons

JSON/CSV/HTML exports for review and automation

What the data already says

Five provisional patterns across the RC1 matrix

Control	Current agent recommendation	What it exposes
Preventive policy	GCP L3 · Azure MIX · AWS L2 · Scaleway L0	Depth of hierarchical deny and policy simulation
MFA enforcement	AWS / Azure L3 · GCP / Scaleway L2	Console MFA is not the same as API/CLI enforcement
External keys	AWS / GCP L3 · Azure L2 · Scaleway L1	Live external keys vs importing keys into provider custody
Data-plane logging	GCP L3* · Azure L2 · AWS / Scaleway MIX	Per-service coverage matters more than one platform label
WAF	AWS / Azure / GCP L3 · Scaleway L2	Managed CRS exists; customization depth differs

Scaleway-specific signal: `enc.hsm-backing` is L0; `gov.preventive-policy` is L0; organization MFA and WAF are managed but limited at L2.

*Provisional: every review is pending; six errored controls are excluded. *GCP's flat L3 data-plane logging result was flagged by consistency checking for confirmation.*

Explore the framework and the code

PROJECT SITE

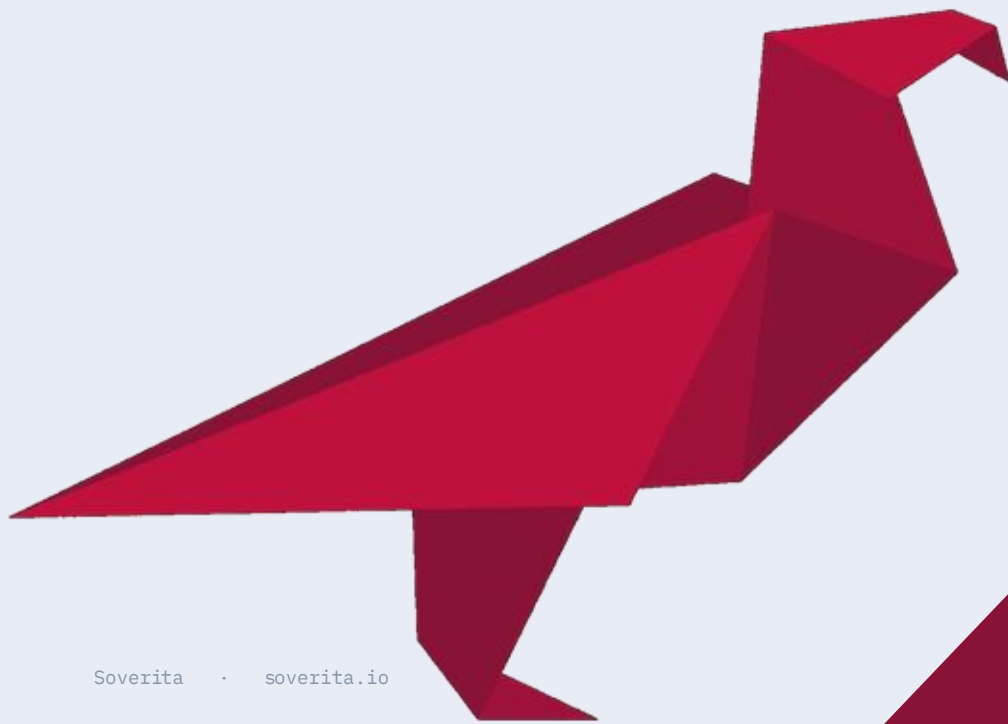


`tenant-sec.io`

SOURCE CODE



`github.com/ypapazov/tenant-sec`



Thank you

*Which trade-off would
change your choice of cloud?*